Pioneiro-REG

Documentação do sistema

Estrutura, funcionalidades, regras de negócio e segurança

Banco v0.17 · 10/10/2026

https://htardelli.github.io/PIONEIRO-REG/

1. Parte 1 — Documentação do sistema
2. Parte 2 — Segurança
3. Anexo — Telas do aplicativo

PARTE 1

Pioneiro-REG — Documentação

Aplicativo (PWA) para o casal acompanhar as horas de **pioneiro regular** por **ano de serviço** (setembro → agosto), com meta anual de **600 h** (mínimo tolerável de **560 h**, com justificativa).

- App: https://htardelli.github.io/PIONEIRO-REG/
- Demonstração (dados fictícios, salvos só no aparelho): https://htardelli.github.io/PIONEIRO-REG/?demo

---

1. Arquitetura

```
 Celular / navegador (PWA instalável, atualização automática)
   └─ React 19 + TypeScript (Vite) ── src/
         │  supabase-js (chave pública "anon")
         ▼
 Supabase (Postgres + Auth)
   ├─ Tabelas com RLS: cada usuário lê o seu e o do cônjuge que compartilhou; escreve só o seu
   └─ Funções "security definer" para escrever no plano/realizado do cônjuge (exigem
compartilhamento mútuo)

 GitHub (repositório público) ── push em main
   └─ Actions (deploy.yml)
        1. Banco: aplica supabase/schema.sql (idempotente, em transação) — segredo
SUPABASE_DB_PASSWORD
        2. Publicação: testes → build → branch gh-pages (GitHub Pages)
```

- **Sem servidor próprio**: o front fala direto com o Supabase. A proteção dos dados é o **RLS** do Postgres (a chave `anon` em `src/config.ts` é pública por definição).
- **Modo demonstração** (`?demo`): a mesma interface com uma API local sobre `localStorage` (`src/api.ts`, `src/demo.ts`), que simula também as funções do banco. `&hoje=AAAA-MM-DD` simula a data.

2. Estrutura de pastas

Caminho	Conteúdo
`src/domain.ts`	Regras puras: ano de serviço, teto de 55 h, ritmo ideal, hh:mm, repetição de datas, conflitos de horário, feriados (nacionais + CE, Páscoa), semana seg–dom, agrupamento de datas seguidas
`src/data.ts`	Carga do ano (`loadYear`) e estatísticas: mês, ano, rateio, estado do dia, faltas, realizado × planejado, semana, alerta de plano abaixo do ritmo, exportação `.ics`
`src/api.ts`	Camada de dados: Supabase (produção) e local (demonstração) com a mesma interface

Caminho	Conteúdo
`src/ui.tsx`	Componentes: barra de abas, cabeçalho, avatar, navegação de mês (grade dos 12 meses), editor de blocos, diálogo de múltipla escolha, legendas
`src/screens/`	Telas: `Painel`, `Lancar`, `Mes` (aba com o nome do mês), `Plano`, `Relatorio`, `Casal`, `Config`, `Auth`, `ChangePassword`
`src/*.test.ts`	Testes (vitest) das regras de negócio e da consistência dos indicadores
`supabase/tests/`	Testes do banco (permissões do casal, RLS, aprovação, senha provisória, salvamento atômico), rodados no CI
`supabase/schema.sql`	Esquema completo: tabelas, RLS, gatilhos e funções (versões v0.2 → v0.17, idempotente)
`.github/workflows/deploy.yml`	Testes do banco + atualização do banco + publicação
`.github/workflows/backup.yml`	Backup semanal criptografado do banco
`docs/`	Esta documentação e os protótipos de layout

3. Modelo de dados (Supabase)

Tabela	Uso	Acesso (RLS)
`profiles`	Nome, cor, metas (600/560 h em minutos), foto (`avatar`), `is_admin`, `must_change_password`, `approved` (cadastro aprovado)	Lê o próprio e o de quem compartilhou; altera só o próprio (gatilho impede mudar `is_admin` / religar troca de senha)
`shares`	Consentimento: `owner` compartilha os **seus** dados com `viewer`	Leitura por quem participa; criação/remoção só via `link_partner` / `unlink_partner`
`modalities`	Modalidades (Cartas, TPE/TPL, Casa em Casa…) com cor e ativa/inativa	Próprio + compartilhado (leitura)
`month_records`	Por mês: meta (opcional), estudos bíblicos, justificativa	idem
`plan_items`	Plano: data, modalidade, minutos, início/fim, `group_id` (atividade conjunta)	idem
`entries`	Realizado: idem + `absent` / `note` (falta por atividade)	idem
`day_notes`	Observação do dia / falta do dia (“Faltei · motivo”)	idem
`credits`	Créditos de horas do mês (tipo, minutos, observação)	idem

Tabela	Uso	Acesso (RLS)
`day_events`	Eventos do dia (congresso, assembleia…), `periods` (dia inteiro ou manhã/tarde/noite), `group_id` quando vale para o casal	idem
`event_types`	Tipos de evento cadastrados em Configurações	idem

Funções principais: - **Acesso**: `can_read`, `is_approved` (conta aprovada), `is_mutual` (compartilhamento mútuo entre contas aprovadas). - **Casal**: `link_partner`, `unlink_partner`, `partner_plan_upsert`, `partner_plan_delete(_dates)`, `partner_entries_add`, `partner_absence_add`, `partner_events_add`, `partner_events_delete` (com validação em `check_partner_items`). - **Administração**: `admin_create_user`, `admin_pending_users`, `admin_set_approval` (aprovar / recusar e excluir).

Todas as que escrevem no cônjuge exigem **compartilhamento mútuo**, só aceitam **atividades conjuntas** e não estão disponíveis para o papel anônimo; as internas (`is_mutual`, `partner_modality`, `check_partner_items`) não podem ser chamadas pelo app.

4. Regras de negócio

- **Ano de serviço**: setembro a agosto. Horas guardadas em minutos e exibidas em **hh:mm** (07:30).
- **Teto mensal**: ministério + crédito ≤ 55 h; o crédito só completa até 55 h e não passa para outro mês (S-236 §11).
- **Alvo do mês**: **plano** do mês; sem plano, a **meta**; sem plano e sem meta, o **rateio** (o que falta para 600 h ÷ meses em aberto sem plano e sem meta). Mês encerrado sem plano/meta: só o realizado.
- **Ritmo ideal**: 600 h proporcional aos dias decorridos do ano de serviço.
- **Meta da semana** (seg–dom): o que falta para 600 h (sem contar a semana) ÷ semanas restantes.
- **Alerta de plano abaixo do ritmo**: mês em aberto cujo plano < média necessária por mês (tolerância 30 min). Pode ser fechado; volta se a situação mudar.
- **Falta**: zera as horas planejadas da atividade/dia (não entram no planejado), mas a **justificativa fica no histórico** (Relatório → Faltas do ano).
- **Atividades de hoje**: só podem ser lançadas **depois do horário de término**; até lá contam como pendentes (nunca como falta).
- **Contagem cumpridas/parciais/faltas**: por **atividade planejada** (pareia o realizado com o plano pela atividade conjunta ou pela modalidade).
- **Alerta de ritmo no Relatório**: só para **mês fechado** cujo acumulado do ano ficou abaixo do ritmo ideal no último dia do mês.
- **Feriados**: nacionais (incl. Sexta-feira Santa), Ceará (19/03 e 25/03) e pontos facultativos (Carnaval, Corpus Christi).
- **Eventos**: dia inteiro ou um ou mais períodos (manhã, tarde, noite); dias seguidos do mesmo evento aparecem numa linha (ex.: 16 - 19/10).
- **Cadastro**: conta criada pelo app só acessa depois da aprovação do administrador; recusar exclui a conta.

5. Telas e fluxos

Painel (ordem: dia → semana → mês → ano)

1. **Alertas**: cadastros aguardando aprovação (administrador) e plano abaixo do ritmo (com ✕ e "Ajustar plano ›").
2. **Hoje** (destaque turquesa): feito / planejado, barra, atividades com horário e descrição, situação, botões **Lançar** e 📅 **Agenda** (.ics dos próximos 30 dias). Com tudo do dia lançado, o botão fica inativo (**Lançado** ✓).
3. **Esta semana**: feito / meta, ponto ideal, barras por dia (plano tracejado × feito) com horas planejadas; "Meta ideal | Seu plano" e "Sugestão".
4. **Mês | Realizado × planejado** até hoje (inclui o plano de hoje; planejado em cinza, realizado em destaque), com contagem por atividade e atalho para dias pendentes.
5. **Mês atual**: feito / alvo e quanto falta.
6. **Ano**: anel (adiantado/atrasado) e barra com Feito · Ideal · Mínimo · Meta.
7. **Meses do ano de serviço** (expansível, inicia oculto) + Planejamento anual.

Lançar

- Seletor de data (calendário). Dias futuros bloqueados.
- ✓ **Cumpri o planejado** (ou "as que já terminaram"), **Fiz diferente**, ✕ **Faltei** (motivo), **+ Atividade não planejada**, **Editar lançamento**.
- Atividade conjunta: "Jessika também participou?" / "também faltou?" — lança para o cônjuge só o que ele(a) ainda não lançou.

Aba do mês (nome do mês vigente)

- Calendário do realizado (cores por situação, contorno nos dias lançados, feriados/eventos) e detalhe do dia com **Plano | Realizado** lado a lado.

Plano

- Calendário (semana começa na segunda), grade dos 12 meses ao tocar no nome do mês.
- Editor de blocos com horário, sem conflito; repetir no mês/ano (avisa e pergunta antes de substituir); excluir por dia/semana/mês/ano.
- **Selecionar vários dias**: excluir plano ou marcar evento. 📌 **Marcar evento** com datas (De/Até), tipo, detalhe e **duração** (dia inteiro ou manhã/tarde/noite).
- **Editar** e **Remover** evento (a sequência inteira de dias; vale também para o cônjuge quando o evento é do casal).
- Feriados e eventos do mês (dias seguidos do mesmo evento numa linha), meta do mês (hh:mm), alvo, planejado no mês e anual.

Relatório

- Texto do relatório (S-4), estudos, créditos com teto de 55 h, exportação para Excel (CSV), justificativa, **Faltas do ano**, alerta de mês fechado abaixo do ritmo.

Casal

- Compartilhar os **meus** dados (consentimento de cada um), comparativo, semana do casal e painel do cônjuge.

Configurações

- Foto do perfil (recortada e reduzida no aparelho), nome, metas, cor, modalidades, **tipos de evento**, **cadastros pendentes** (aprovar/recusar) e criação de conta com senha provisória (somente administrador), sair, versão.

Login e cadastro

- **Entrar** ou **Pedir cadastro**. O cadastro fica "Aguardando aprovação" até o administrador aprovar; o Painel do administrador avisa quantos aguardam.

6. Identidade visual

- **Fonte Ruda**, empacotada no app (funciona sem internet, sem depender do Google Fonts).
- **Cores com significado**: verde = feito · amarelo = parcial · vermelho = falta/feriado · roxo = evento/ideal · azul = plano · **turquesa = hoje**.
- Horas sempre em **hh:mm**; semana de **segunda a domingo**; números do dia no canto superior esquerdo e contorno nos dias lançados.

7. Publicação e operação

- **Push em `main`** → GitHub Actions aplica o banco (se `supabase/` mudou) e publica o app.
- **Segredo**: `SUPABASE_DB_PASSWORD` (só a senha). O log nunca exibe a senha (máscara); permissões mínimas no workflow.
- **PWA**: atualiza sozinho ao abrir (verifica a cada 30 min e ao voltar ao app); a versão aparece em Configurações.
- **Salvamento atômico (v0.15)**: lançar o dia (`save_day`) e salvar o plano (`save_plan`) rodam numa única transação no banco — ou grava tudo, ou nada muda. Se falhar (sem internet), o que foi digitado fica como **rascunho neste aparelho**; ao abrir o dia aparece "Lançamento não salvo · Recuperar / Descartar".

Backup e restauração

- **Automático**: workflow `Backup do banco` todo domingo (03:17 de Fortaleza) e sob demanda (Actions → Backup do banco → Run workflow).
- Gera `pioneiro-backup-AAAA-MM-DD.tar.gz.enc` (dados do app + contas), **criptografado com AES-256** usando o segredo `BACKUP_PASSPHRASE` , guardado 90 dias como artefato da execução.
- **Segredo obrigatório**: `BACKUP_PASSPHRASE` (12+ caracteres) em Settings → Secrets and variables → Actions. **Guarde essa senha fora do GitHub** (gerenciador de senhas): sem ela o backup não abre.
- Restaurar (computador com `openssl` e `psql`):
  1. Baixe o artefato na execução do Actions e descompacte o `.zip` .
  2. `openssl enc -d -aes-256-cbc -pbkdf2 -iter 600000 -in pioneiro-backup-AAAA-MM-DD.tar.gz.enc | tar -xzf -` (pede a senha) → `contas.sql` e `app.sql` .

3. Num projeto Supabase **novo** (ou após apagar o schema `public` no atual): `psql "<endereço do Session pooler>" --single-transaction -f contas.sql -f app.sql`.
4. Rode `supabase/schema.sql` em seguida (recria o gatilho de cadastro e confirma permissões) e atualize `src/config.ts` se o projeto mudou.

- Efeito colateral útil: o acesso semanal evita que o Supabase gratuito pause o projeto por inatividade. O GitHub desativa agendamentos após 60 dias sem atividade no repositório — nesse caso, reative em Actions.

8. Desenvolvimento

```
npm install
npm run dev     # http://localhost:5173/PIONEIRO-REG/?demo
npm test        # regras de negócio + consistência dos indicadores (Painel × Mês × Relatório)
npm run build
```

9. Segurança

Ver SEGURANCA.md — modelo de ameaças, revisão e pendências.

10. Revisão de fluxos (outubro/2026)

Corrigido - “Fiz diferente” deixava a atividade do plano pendente e “Cumpri” depois somava horas em dobro: dia passado lançado não tem mais pendências, e o “Cumpri” verifica conflito de horário. - Ano de serviço anterior: no início de setembro dá para lançar agosto (Lançar volta até 01/09 do ano anterior) e ver o Relatório de agosto (‹ no Relatório). - “Hoje” não congela mais com o app aberto (virada do dia e ao voltar ao app). - Plano: “Repetir” + “Pular dias” + “Para todos” não apaga mais a atividade do cônjuge nos dias pulados; desmarcar “Com cônjuge” desvincula a atividade. - Falta conjunta parcial não aparece mais como “faltou o dia”; conta como falta (não como “não lançada”). - Falta conjunta lançada pelo cônjuge pode ser desfeita (“Desfazer falta”). - Dia passado sem lançamento aparece como pendente (tracejado) no Mês e no Plano, não como falta. - “Repetir no mês” não reescreve dias passados. - A nota “Faltei…” é limpa quando o dia passa a ter horas; o relatório S-4 não mostra “00:00 de crédito”. - Alerta do Painel do cônjuge não fecha o seu.

Resolvido depois (v0.15 – v0.17) - Salvar o dia/plano agora é atômico, com rascunho local em caso de falha; backup semanal criptografado. - Salvar o dia sem horas pergunta “Foi falta?” com o motivo (dia sem plano: oferece apagar o lançamento). - Testes automáticos no CI: `supabase/tests/casal.sql` (permissões do casal, RLS, aprovação, senha provisória, salvamento atômico) num Postgres local antes de tocar no banco real; o deploy só segue se passarem. - Evento que atravessa meses aparece numa linha só (ex.: 29/09 - 02/10) e editar/remover vale para a sequência inteira; o mesmo evento não se repete no dia (índice único, v0.17). - Dias restantes contam hoje no anel e no card do mês. - Troca obrigatória de senha imposta no servidor (v0.16): com senha provisória a conta não lê nem grava dados; a marca só cai quando a senha realmente muda.

Pendências conhecidas (baixo impacto) - “Excluir planejamento” por semana/ano a partir de um dia passado preserva dias passados (inclusive o escolhido) se “incluir dias que já passaram” não estiver marcado. - Meta anual em Configurações em horas inteiras; o .ics exporta também atividades com falta.

PARTE 2

Segurança — Pioneiro-REG

Revisão de outubro/2026 (banco, funções, front-end e publicação) — atualizada até a versão v0.16 do banco.

Modelo de proteção

- **Dados no Supabase (Postgres) com RLS em todas as 10 tabelas** (e só para contas **aprovadas**): cada pessoa grava só os próprios dados (`user_id = auth.uid()`) e lê os próprios e os de quem **compartilhou com ela** (`can_read`).
- **Compartilhamento por consentimento**: cada um compartilha os **seus** dados (`link_partner` grava sempre `owner = quem chamou`). Ninguém consegue se colocar como leitor de outra pessoa.
- **Escrita no cônjuge** só por funções `partner_*` e só com **compartilhamento mútuo** — e apenas para **atividades conjuntas** (com `group_id`), com datas numa janela razoável e listas limitadas.
- **Perfil**: ninguém se promove a administrador nem religa a troca obrigatória de senha (gatilho `protect_profile_flags`).
- **Contas novas**: pelo cadastro do app (**nasce bloqueada** até o administrador aprovar em Configurações → Cadastros pendentes; recusar exclui a conta) ou criadas pelo administrador (senha provisória, troca obrigatória, já aprovadas). Conta pendente não lê nem grava dados (RLS exige `is_approved()`), não compartilha e não se aprova sozinha.
- A chave `anon` em `src/config.ts` é **pública por definição**; a proteção é o RLS.

Achados e correções (v0.12)

#	Severidade	Achado	Situação
1	Média	Compartilhamento mútuo permitia ao cônjuge gravar lançamentos/planos **não conjuntos** (sem `group_id`), em qualquer data e em quantidade ilimitada; textos sem limite	**Corrigido**: `check_partner_items` exige `group_id` , limita a 1000 itens, datas entre –400 e +400 dias (realizado: no máximo até amanhã); textos truncados. Texto da tela Casal ajustado
2	Média	Funções `can_read` , `link_partner` , `unlink_partner` , `is_mutual` e `partner_modality` executáveis pelo papel anônimo; `partner_modality` sem checagem (vazava o nome do perfil)	**Corrigido**: `revoke` do anônimo; `is_mutual` / `partner_modality` só internas; `partner_modality` exige compartilhamento mútuo

#	Severidade	Achado	Situação
3	Média	Cadastro público + `link_partner` permitiam descobrir se um e-mail tem conta	**Corrigido (v0.13)**: cadastro só com aprovação do administrador; conta pendente não chama `link_partner` nem vê dados
4	Média/Baixa	Um estranho que compartilhasse com a vítima podia aparecer como "cônjuge" e usar foto/cor externas (rastreamento)	**Corrigido**: cônjuge = compartilhamento **mútuo** (escolha estável); cor só hexadecimal; foto só JPEG pequeno em data URL (≤150 KB); **CSP** só permite recursos do app e o Supabase do projeto
5	Baixa	Injeção de fórmula no "Exportar Excel"	**Corrigido**: células iniciadas por `= + - @` são neutralizadas
6	Baixa	Quebra de linha não escapada no `.ics`	**Corrigido**
7	Baixa	CI com permissão de escrita em todos os jobs; diagnóstico da senha (tamanho/tipos) no log público	**Corrigido**: permissão mínima (escrita só no job de publicação), checkout do banco sem credenciais, diagnóstico removido
8	Baixa	Arquivo de teste `erro.txt` com endereço de conexão do banco no **histórico** do repositório público	**Encerrado**: arquivo removido; o endereço do histórico era de teste e não contém a senha real (confirmado pelo responsável)
9	Info	Troca obrigatória de senha era imposta só no app	**Corrigido (v0.16)**: `is_approved()` exige a troca feita; a marca só é desligada por gatilho quando a senha muda em `auth.users`; o app não consegue alterá-la

Ações pendentes (manuais, no painel)

1. **Criar o segredo `BACKUP_PASSPHRASE`** (12+ caracteres) no GitHub e guardar a senha fora do GitHub. O backup só é gerado criptografado: como o repositório é público, um artefato sem criptografia poderia ser baixado por terceiros.
2. **Supabase → Authentication → Sign In / Providers → "Allow new users to sign up" → manter LIGADO** (o cadastro passa pela sua aprovação no app).
3. (Opcional) Fixar as actions do workflow por SHA em vez de `@v4`.

Verificado e OK

- Nenhum `dangerouslySetInnerHTML` / `eval`; o React escapa os textos; links externos com `encodeURIComponent`.
- `shares` sem política de inserção direta; `profiles` sem inserção/remoção direta.

- `admin_create_user`: exige `is_admin`, valida e-mail e senha (8+), senha com bcrypt, indisponível ao anônimo.
- Funções `security definer` com `search_path` fixo e sem SQL dinâmico com entrada do usuário.
- Lançar/planejar: funções `save_day` / `save_plan` em `security invoker` (o RLS continua valendo) e com limites de tamanho.
- Modo demonstração (`?demo`) totalmente local; service worker só guarda o app (não a API).
- Segredo do banco mascarado no log; publicação só por `push` em `main` ou execução manual.

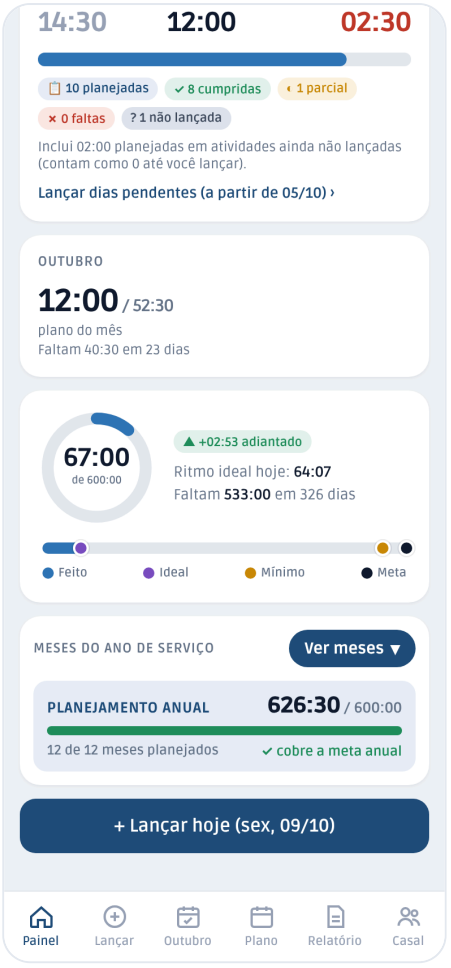
ANEXO

Telas do aplicativo

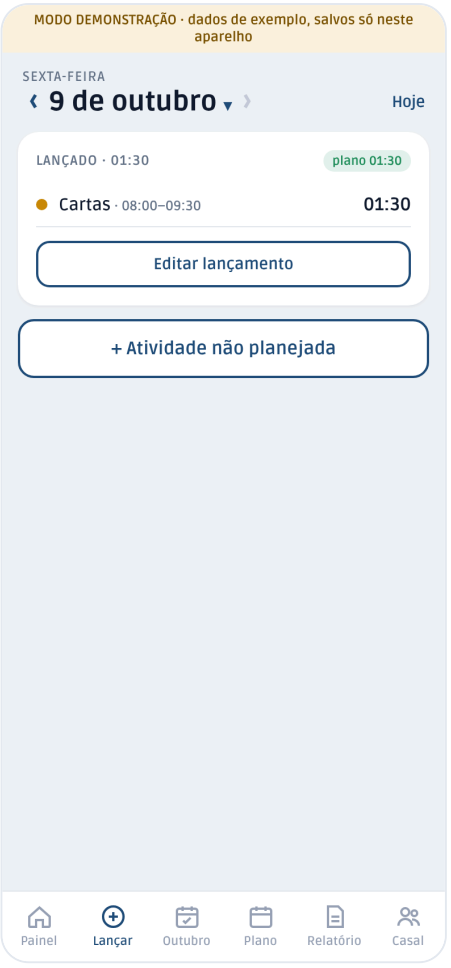
Capturas do modo demonstração (dados fictícios), em tamanho de celular.



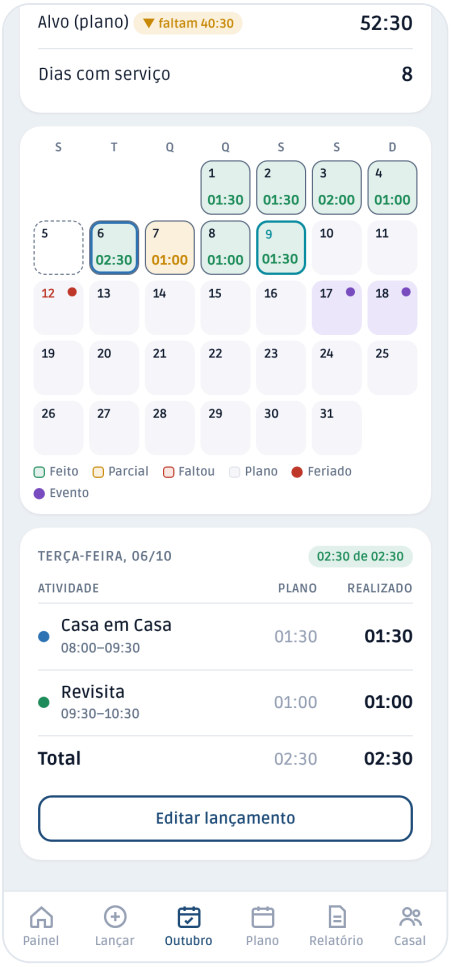
Painel — alerta, Hoje e semana



Painel — mês e ano



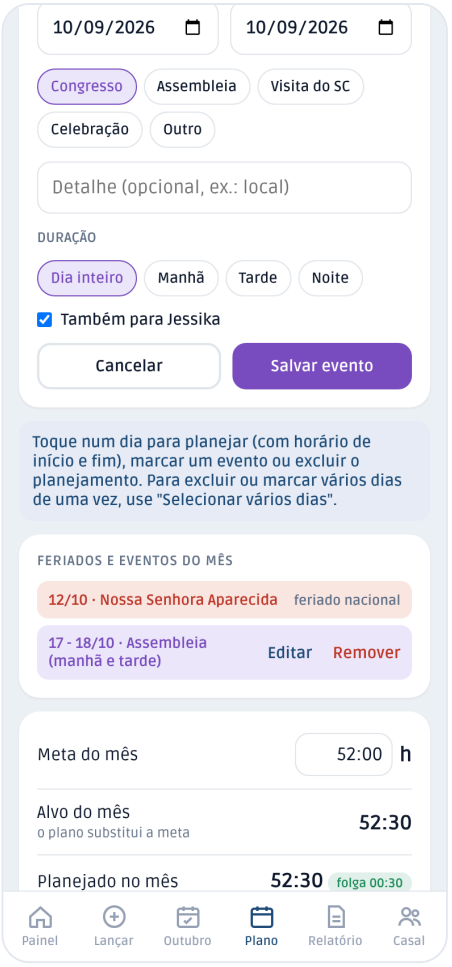
Lançar



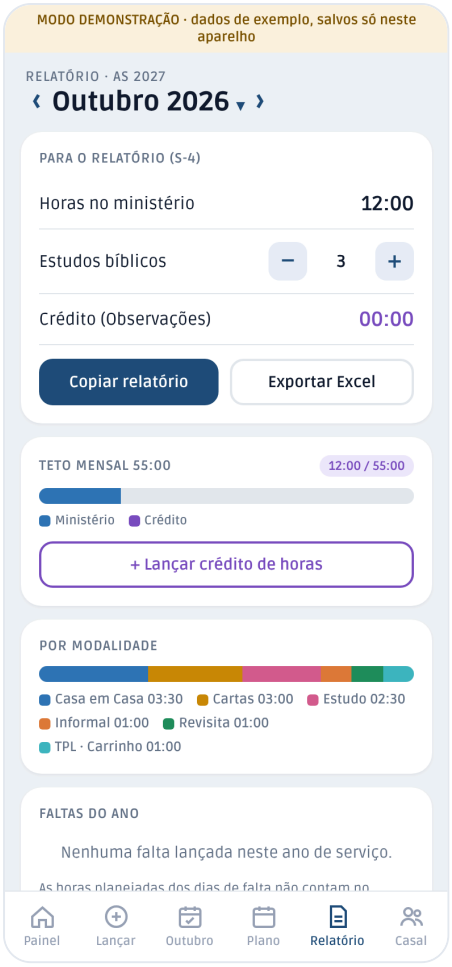
Aba do mês — calendário e detalhe do dia



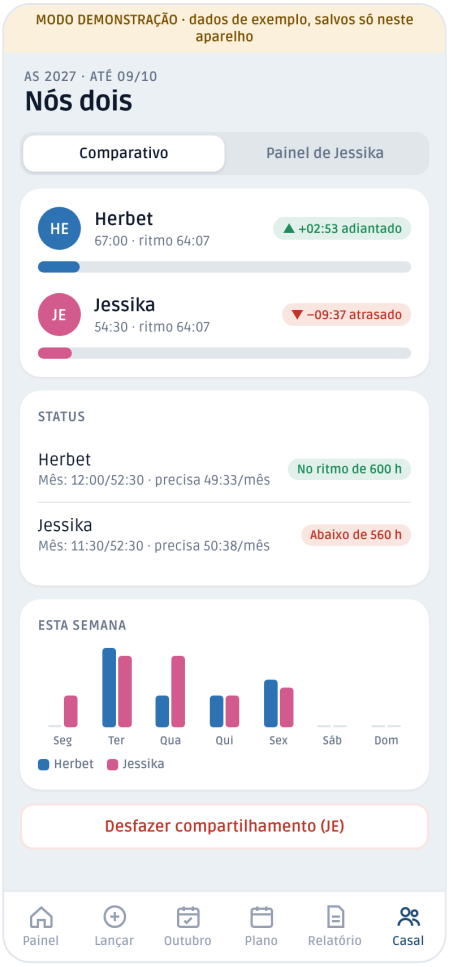
Plano — calendário



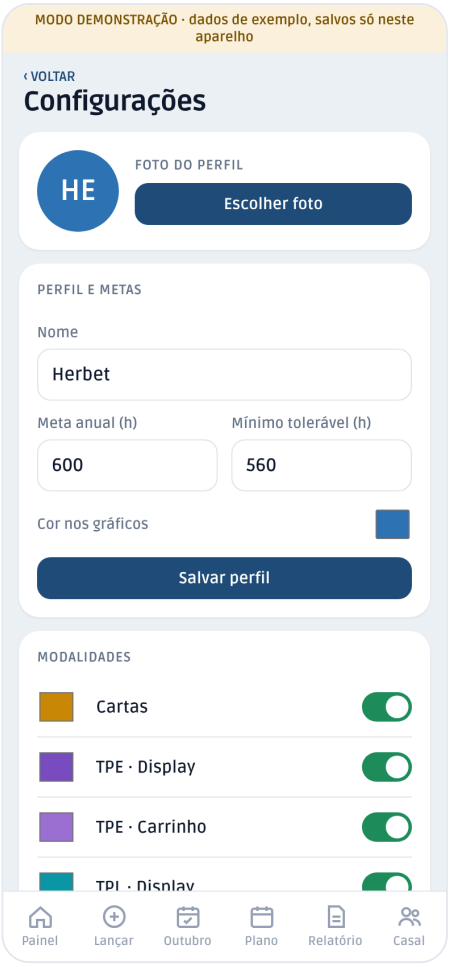
Plano — evento com duração



Relatório



Casal



Configurações